CRM Application Security Architecture

PBL Milestone: Application Security Architecture and Software Engineering Integration

III-BCSAD • bolanatics • 5 October 2026

Center for Research Management (CRM) Research Services and Information Management Platform

Repository: https://github.com/a-a123456789/umak-research-management

Member / student ID	Classroom C-suite / engineering role	Section owner
Arnaez, Anjelo Benedict / K12254175	CEO / executive sponsor	IV and final compilation
Ducay, Justin Andrew / A12448793	CIO / infrastructure lead	II; diagram and recovery support
Balocating, Aaliyah Marie / A12448769	CISO / risk lead	V–VI; framework alignment
Maligaya, Gian Brent / A12448912	Lead software engineer / DevSecOps	I; code, Git and demonstration
Bomediano, John David / A12448927	DPO / compliance specialist	III; privacy/legal review

Writing assignments do not alter defense responsibilities. These roles describe the five-student project team; they are not appointments to university offices. No signature, official notification or human review is asserted. One designated member submits the portfolio and repository URL through TBL Hub. Confirm the official deadline separately.

Executive scope and evidence status

This report consolidates the six laboratory topics around the implemented synthetic CRM backend. It preserves the completed team sections as source material while correcting mismatched project names, stack claims, legal statements, risk assumptions and evidence. CRM means Center for Research Management. “Online Repository Management System” and “UMak-RMLIS” are earlier labels for this course project, not evidence of additional deployed systems [1].

The implementation uses Express/Node 24, PostgreSQL 18, local bearer sessions, Python DAG computation and GitHub Actions. No complete frontend, cloud deployment, Google SSO, Redis, uploads or Turnitin integration is claimed. Production-grade architecture is the design target; the submitted system is a bounded teaching prototype. Production approval depends on institutional policy, HTTPS, operational isolation, retention and human review.

Local checks and integration GitHub CI have executed. Commands, outputs and commit IDs are retained under `evidence/integration/`; exact final merge and protection status belongs to the completion ledger. Financial inputs remain scenario estimates, incident response is an academic simulation, and automated checks are distinct from peer review.

I. Enterprise governance and asset inventory

System profile and reporting lines

The system supports approved research discovery, authenticated record creation/read access, optional privacy preferences, reviewed synthetic deletion, and staff-only workflow estimation. Researchers and CRM staff are distinct application roles. Git contributors and database administrators are separate operational identities; being a student CEO does not automatically grant a staff API account or production database access.

Classroom reporting: Lead Engineer and CIO report implementation/recovery evidence to CEO; CISO reports threat priorities and residual risks directly to CEO; DPO independently raises privacy concerns to CEO and the actual institutional authority when appropriate. The CISO can request a release hold for an unresolved severe flaw, while CEO records the project decision. Actual university officers retain institutional authority. This separates budget/scope decisions, technical execution and risk review [2], [3].

CEO owns priorities and risk acceptance; CIO owns environment, backups and architecture accuracy; CISO owns STRIDE, DREAD, register and NIST/ISO alignment; Lead Engineer owns patches, tests and Git configuration; DPO owns legal mapping, data minimization and simulation labeling. A release exception requires a reason, exact affected rule, passing evidence and restoration record. This integration's owner-authorized approval exception is not peer review.

Asset inventory and classification

The following are stable IDs for actual prototype components and explicitly proposed persistence, not an inventory of real university records. Confidentiality classes apply to intended data; current records are synthetic.

ID / asset	Custodian / location	Classification	Security priorities
A-01 identities, sessions, consent	Gian / PostgreSQL	Restricted	Confidentiality, authenticity, privacy; prevent impersonation
A-02 research records and backups	Justin / operational DB and temporary dump	Confidential; approved metadata public	Confidentiality, integrity, availability, Safety (avoid harmful disclosure or loss)
A-03 service-workflow records	John David / proposed persistence adapter	Confidential, proposed	Integrity, privacy, authentic evidence gates
A-04 public research information	Justin / approved search response	Public	Integrity and availability; public does not mean writable
A-05 credentials	Gian / ignored local environment, ephemeral CI	Restricted	Confidentiality and Safety (avoid harmful disclosure or loss)
A-06 source, CI and models	Gian / private Git repository	Internal	Integrity, authenticity and availability
A-07 audit events	Aaliyah / logical audit store in PostgreSQL	Confidential	Integrity, accountability and controlled retention
A-08 workflow scenarios/results	Gian / bounded worker memory and response	Internal synthetic; future confidential	Integrity, availability and honest estimate interpretation

CIANA-PS follows the milestone definitions: Confidentiality, Integrity, Availability, Non-Repudiation, Authenticity, Privacy and Safety. Safety means reducing foreseeable harm to researchers from disclosure, corrupted decisions or unavailable services; this prototype is not a safety-critical certified system. Attributable logs support accountability but do not establish cryptographic non-repudiation [2], [4].

Student / reports to	Routine governance duty	CIANA-PS contribution
Anjelo, CEO / team and institutional sponsor	Set scope, fund controls, record release decisions	Availability and Safety; authorize residual risk only after review
Justin, CIO / CEO	Operate database, backup and recovery	Availability and Integrity
Aaliyah, CISO / CEO directly	Assess threats, challenge exceptions, monitor evidence	Confidentiality, Integrity and Non-Repudiation

Student / reports to	Routine governance duty	CIANA-PS contribution
Gian, Lead Engineer / CIO for operations; CEO for delivery	Implement access rules, tests and CI	Authenticity, Integrity and Availability
John David, DPO / CEO; independent escalation to institution	Review consent, erasure and incident simulation	Privacy and Confidentiality; Safety of data subjects

The business data owner decides permitted use and retention; the custodian implements storage and approved access. The student CEO models the owner's project decisions and the CIO models custody, without claiming university appointment. Direct CISO-to-CEO reporting lets unresolved security issues reach the decision maker without being filtered by delivery management [2], [3].

Conflict example: Gian requests a release while a severe authorization defect remains. Aaliyah presents the affected asset and failed test; John David assesses privacy harm; Justin estimates recovery impact; Anjelo records a defer-or-accept decision. Proposed team tolerance: no release with failing mandatory checks, exposed credentials or demonstrated unauthorized disclosure. Financial acceptance thresholds require institutional confirmation. The earlier review-count exception did not waive security checks and did not constitute peer review.

Governance acknowledgment — unsigned

These are classroom allocations. Each member must read their obligations before signing; blank fields are intentional external actions.

Member	Acknowledgment signature	Actual date
Anjelo Benedict Arnaez	_____	_____
Justin Andrew Ducay	_____	_____
Aaliyah Marie Balocating	_____	_____
Gian Brent Maligaya	_____	_____
John David Bomediano	_____	_____

II. Attack surface, Kill Chain and code remediation

Actual stack and attack surface

Entry/component	Asset / failure mode	Implemented control	Evidence / remaining limit
Express public search	A-02/A-04 SQL injection, broad result sets	Parameterized query, Approved filter, 100-row cap, 200-character keyword	SQLi demo and regression test; no full penetration test
Login/session routes	A-01 brute force, token theft	Salted scrypt, random hashed one-hour bearer token; login/general throttling; revocation	Auth tests; local HTTP requires production HTTPS
Record read/create	A-02 object access or forged ownership	Owner-or-staff predicate; server author ID; Draft-only creation	Cross-user denial and staff success tests
Consent/deletion	A-01/A-02 forged choices or erasure	Strict fields, server identity/time, staff-reviewed transaction	Privacy tests; backup erasure is proposed
Algorithm solve/worker	A-08 DoS, forged evidence scenario	Staff-only, graph limits, two workers, timeout, output cap, fixed script/no shell	Worker/API tests; scenario not institutional verification
PostgreSQL	A-01/A-02/A-07 excessive privilege	Separate non-owner runtime; PUBLIC grants revoked; audit INSERT/SELECT only	Permission tests; no RLS or immutable audit system
Git and CI	A-05/A-06 committed secrets/supply chain	Local hook, Gitleaks, Semgrep, dependency audit, required checks	Actual hook rejection and CI; native private-repo push protection unavailable
Optional external services	Proposed identity/storage/upload features	No active integration or route	Review before enabling; do not claim current attack evidence

Vulnerability classifications: SQL injection is CWE-89; missing authorization is CWE-862; uncontrolled resource consumption is CWE-400. Parameterization and explicit authorization align with OWASP verification guidance [5], [6]. The isolated vulnerable app is never imported by normal startup.

Seven-phase Kill Chain with ATT&CK mapping

This seven-stage tabletop targets the existing developer workstation, ignored credentials and PostgreSQL research collection. It assumes a malware operator gains the workstation user's execution rights through a malicious file outside the CRM app. No upload feature, observed intrusion or executed malware is claimed. The sequence is a hypothesis for defense planning; the executed SQLi experiment below is separate. Kill Chain phases and ATT&CK tactics are related but are not interchangeable taxonomies [7], [8].

Phase	Hypothetical action / ATT&CK ID	Control or limit
Reconnaissance	Discover exposed routes when the local service is reachable / T1595.002	Minimal routes; no external reconnaissance performed
Weaponization	Prepare a credential-stealing executable / T1587.001	No malware built; trusted developer tooling is an operational requirement
Delivery	Send that file to the developer as a phishing attachment / T1566.001	Outside CRM ingestion; awareness training proposed
Exploitation	Developer executes the malicious file / T1204.002	Requires user execution, not an imaginary upload/parser flaw
Installation	Persist as a user cron job on the Unix host / T1053.003	OS hardening/monitoring proposed; no persistence installed
Command and control	Contact an attacker web service / T1071.001	Egress monitoring proposed; no connection executed
Actions on objectives	Use stolen local admin credentials to encrypt reachable research/backup data / T1486	Runtime least privilege and synthetic recovery tested; workstation isolation/offsite recovery remain gaps

Actual vulnerable and patched proof

The demonstration creates temporary synthetic tables and runs the same UNION payload against the isolated concatenating example and the normal parameterized search. It then removes its temporary schema. The vulnerable result contains a fake credential sentinel; the patched result is HTTP 200 with an empty array. Successful prevention need not return 401 because search itself is public.

Repository vulnerable example (`demo/vulnerable-app.js`, isolated synthetic demonstration):

```
// INTENTIONALLY VULNERABLE: loaded only by scripts/demo-sqli.js in an isolated schema.
import express from 'express';
export function vulnerableApp(db) {
 const app=express();app.use(express.json());
 app.post('/api/v1/research/search',async(req,res)=>{
   const query="SELECT id,title,abstract,status FROM research_records WHERE status='Approved' AND title LIKE
'%" + req.body.keyword + "%'";
   const r=await db.query(query);res.json(r.rows);
 });
 return app;
}
```

Normal endpoint query (`src/app.js`):

```
const r=await db.query(
 "SELECT id,title,abstract,status FROM research_records WHERE status='Approved' AND title ILIKE $1 ORDER BY id
 LIMIT 100",
 ['%'+keyword+'%']);
res.json(r.rows);
```

Same malicious request in both tests:

```
POST /api/v1/research/search
Content-Type: application/json
```

```
{"keyword":"' UNION SELECT id, email, password_hash, role FROM users--"}
```

Recorded server responses from the local synthetic run at commit `655114e`:

```
{"before":{"status":200,"body":[
 {"id":99,"title":"synthetic@example.test","abstract":"FAKE_HASH_NOT_A_CREDENTIAL","status":"student"},
 {"id":1,"title":"Public synthetic record","abstract":"Public abstract","status":"Approved"}]},
 "after":{"status":200,"body":[]},"result":"PASS"}
```

Actual command: `npm run demo:sqli`. The before/after JSON and PASS assertion are recorded in `evidence/integration/local-checks.txt`. Tests separately check approved-only normal results, cross-user denial, valid staff access and malformed input. The demo proves a specific query control on synthetic data; it does not prove every route or database grant is secure.

III. Legal compliance, privacy by design and incident response

The following are engineering mappings for academic analysis, not legal certification. The actual institutional DPO must confirm processing purposes, lawful basis, retention and notification decisions. Older statutes and the 2016 NPC circular are deliberately cited using their actual dates [9]–[11].

Five provisions from each law

Law / provision	CRM design implication	Control and verification boundary
RA 10173 §11	Transparency, legitimate purpose, proportionality	Collect minimal consent fields; privacy notice and retention schedule need institutional confirmation
RA 10173 §12	Establish lawful processing criteria	Optional choices recorded separately; no claim that a checkbox legalizes core processing
RA 10173 §13	Special conditions for sensitive/privileged data	Synthetic data only; real educational/research data classification and authority review required
RA 10173 §16	Data-subject rights including applicable blocking/removal	Reviewed deletion request; real rights workflow/retention exceptions need confirmation
RA 10173 §20	Appropriate organizational, physical and technical safeguards	Tested authorization, session handling and backup recovery; production safeguards remain partly proposed
RA 10175 §4(a)(1)	Illegal access risk	Authentication, staff/owner checks, database privilege separation
RA 10175 §4(a)(2)	Illegal interception risk	Production TLS required; local HTTP is not protected transport evidence
RA 10175 §4(a)(3)	Data interference risk	Parameterized SQL and constrained record writes; audit attribution
RA 10175 §4(a)(4)	System interference risk	Body/graph/concurrency/time limits and restoration exercises
RA 10175 §4(a)(5)	Misuse of devices risk	Restrict credential/tool access; keep vulnerable demonstration isolated and authorized

Consent JSON and API

Authenticated `POST /api/v1/users/consent` accepts exactly `policy_version` and `choices`. The supported version is `2026-10-v1`. Choices are two required booleans; both may be false. Client-supplied user ID or timestamp is rejected. The server records identity from the session and time from PostgreSQL; repeated requests append preference history, with the latest record representing current optional choices.

```
{"policy_version":"2026-10-v1",
 "choices":{"institutional_analytics":false,"email_notifications":false}}
```

HTTP 201 returns `id,user_id,policy_version,choices,recorded_at`; invalid fields/version return 400; missing or invalid session returns 401. No IP address, user agent, real name, email-delivery integration or analytics processing is added by this route. Production must explain purpose, withdrawal, retention and the distinct lawful basis for necessary service processing [9].

Deletion and backup handling

A student sends `{}` to `POST /api/v1/users/deletion-requests`; HTTP 202 returns request ID, status and server request time. Repeating a pending request reuses it. Only staff can complete `/api/v1/admin/deletion-requests/:id/complete` with `{"confirm_review":true}`. The transaction deletes the synthetic user and cascades research records, sessions and consents; the request loses its personal user link and a minimal staff-attributed audit event remains. Completion returns a warning that backup erasure is not implemented.

Soft deletion only hides records. Hard deletion removes operational rows but does not erase historical backups. Proposed production procedure: confirm authority/holds; erase eligible data; maintain a restricted deletion ledger outside backups; expire recovery copies on an approved retention schedule; replay deletion events after restoration before opening traffic; review audit retention and minimize retained identifiers. Cryptographic shredding requires per-subject encryption keys and verified destruction of all recoverable copies; no KMS or shredding implementation is claimed.

Proposed production erasure design — not implemented

Method	Live data	Historical backups	Decision / verification
Soft deletion	Hidden, recoverable rows	Unchanged	Useful for review/holds; not erasure
Hard deletion	Operational rows removed	Old copies remain readable	Current prototype behavior; restore must replay authorized deletions
Cryptographic erasure	Encrypted personal fields unreadable after key destruction	Effective only if every recoverable subject key is destroyed	Proposed architecture; not claimed for current plaintext fields

Proposed sequence: (1) authenticate the requester and record the lawful decision and any required hold; (2) locate subject data across tables, exports, caches and backups; (3) remove eligible live rows and minimize retained audit identifiers; (4) record a restricted deletion event outside routine backup snapshots; (5) quarantine each restore and replay those events before reopening access; (6) expire backup generations on an institution-approved schedule and document verification. No arbitrary retention period is asserted [9], [17].

For a future encryption design, encrypt each subject's fields with a distinct data-encryption key and keep recoverable subject keys in a separately governed key service, not inside the database dump. Destroy all key versions, replicas, escrow and recoverable backups for an approved subject deletion; verify that restored ciphertext cannot be decrypted. Shared keys cannot selectively erase one person's records. Cryptographic erasure does not remove plaintext exports, logs or prior copies: those need separate sanitization and evidence. This design needs implementation, key inventory and recovery tests before a permanent-erasure claim [16]. Required financial/audit retention must be established by the institution; retain only necessary records under that authority, not a blanket exception [17].

Six-stage incident response — academic simulation

Scenario: a synthetic alert suggests unauthorized research disclosure. No actual university incident, affected-person count, containment action or notification is asserted. The six stages below are a rehearsal playbook; production timing and responsibility must be adopted by the real institution [11], [12].

Stage	Owner and action	Evidence to produce in a real incident
Identify	CISO triages alert; DPO assesses personal-data exposure	Record discovery time, source, confidence and known unknowns
Contain	CIO/Engineer restrict affected route and revoke compromised sessions/credentials	Preserve logs before destructive changes; record scope and containment time

Stage	Owner and action	Evidence to produce in a real incident
Analyze	CISO/Engineer correlate authorized logs and changes	Identify affected data, access path and uncertainty; preserve chain of custody
Eradicate	Engineer patches root cause and rotates affected credentials	Reviewed fix, dependency review and repeated exploit test
Recover	CIO restores verified copies and checks integrity	Replay approved deletions before traffic; compare records and monitor recurrence
Lessons learned	CEO convenes CISO/DPO/team	Update policies, threat model, backlog and training; document accountable follow-up

NPC notification is not triggered by every security event. Assess the legally specified breach conditions and, when notification is required, the 72-hour requirement runs from knowledge or reasonable belief as specified in the applicable rules. Uncertainty must be communicated and updated, not replaced with invented facts [11].

Draft NPC notice — ACADEMIC INCIDENT SIMULATION, NOT SUBMITTED

To: National Privacy Commission (submission channel to be verified by actual institutional DPO). Reporting controller: [actual institution and authorized contact to be confirmed]. Discovery time: [unknown; enter verified time]. Nature: suspected unauthorized disclosure of research-related personal data. Data and individuals affected: [categories/count unknown pending investigation]. Likely consequences: [assessed risks, not assumed actual harm]. Containment and recovery: [verified actions/times only]. Measures for affected people: [reviewed guidance]. Notification basis and timing: [DPO assessment and evidence]. Next update: [authorized schedule]. No signatory or official appointment is fabricated. This template must not be sent as an actual incident report.

IV. EISP, system policy and Git guardrails

Five-part Enterprise Information Security Policy charter

1. Executive Philosophy: protect research participants, trustworthy records and service continuity. Proposed risk tolerance prohibits release with failing mandatory checks, exposed credentials or demonstrated unauthorized disclosure; institutional risk acceptance is separate. 2. Scope of Application: cover team devices, source, CI, the synthetic Express/PostgreSQL service, Python worker, local backups and submitted documentation. University production adoption is not asserted. 3. Roles and Responsibilities: CEO records decisions; CIO operates infrastructure; CISO evaluates threats and exceptions; Lead Engineer implements and tests; DPO reviews privacy. Follow the reporting table in Section I. 4. Statutory Directives: assess RA 10173 and RA 10175 obligations using the mappings in Section III [9], [10]; use ISO/IEC 27001:2022 for a proposed governance roadmap, not a certification claim [3]. Default deny, least privilege, secret exclusion and tested recovery are team requirements. 5. Administrative Review Cadence: review at each milestone, after material architecture changes and after incidents. Record exception owner, reason, expiry and compensating checks. Monthly access review is proposed; no completed meeting or invented disciplinary sanction is asserted.

Managerial policy

Changes require an identifiable author, linked risk/ticket, passing checks and normal peer review. The project owner may authorize a documented one-time review exception with restoration; passing CI is not peer approval. Production processing, hosting and retention changes require the actual institutional authority. Monthly classroom access reviews and per-release recovery rehearsal are proposed operating routines, not claims of completed meetings.

Five-column default-deny ACL

Subject	Resource / action	Decision	Condition	Enforcement / evidence
Anonymous	Health; approved research search	Allow read	Valid bounded keyword; Approved only; max 100 rows	Express public routes and search tests
Anonymous	Private records, consent, solver, audit	Deny	No valid session	401 assertions
Student	Own record read / own Draft creation	Allow	Authenticated identity; server ownership	SQL owner predicate and creation tests
Student	Another owner's private record / staff route	Deny	No ownership/staff grant	404 object hiding / 403 staff denial
Student	Own consent / deletion request	Allow	Valid body, policy and session	Privacy tests and server identity
Staff	Record reads, audit reads, reviewed deletion	Allow	Staff role; explicit deletion confirmation	Staff middleware and transaction tests
Staff	Algorithm scenario solve	Allow	Strict graph/body bounds; worker admission	Algorithm API and failure tests
Runtime DB role	Operational queries; audit INSERT/SELECT	Allow scoped grants	Non-owner authenticated DB connection	Schema grants and DB permission tests
Runtime DB role	Audit UPDATE/DELETE; schema DROP	Deny	Never granted	SQLSTATE 42501 assertions
Any unlisted subject/action	Any resource	Deny	No explicit rule	Route 404, middleware and revoked PUBLIC privileges

Working configuration lives in `src/app.js`, `src/algorithm.js`, `db/schema.sql`, `compose.yaml`, `.githooks/pre-commit`, `.gitleaks.toml`, `.semgrep.yml` and GitHub workflows. The local HTTP binding is loopback; deployment TLS and network controls are not inferred from a diagram [13].

Comparative framework roadmap

Phase / owner	NIST CSF 2.0 alignment	ISO/IEC 27001:2022 alignment	Concrete deliverable
Define / CEO+CISO	Govern, Identify	Clauses 4–6 context, leadership, planning	Scope, asset owners, risk register and acceptance criteria
Implement / CIO+Engineer	Protect, Detect	Clause 8 operation; selected Annex A controls	Access/configuration rules, secure development checks, attributable logs
Rehearse / CIO+DPO	Respond, Recover	Operational response and continuity controls	Synthetic playbook, restore evidence, breach assessment template
Evaluate / CISO+CEO	Govern and improvement across functions	Clauses 9–10 evaluation and improvement	Review metrics, residual-risk decisions and corrective backlog

NIST supplies a flexible outcomes vocabulary; ISO 27001 specifies an auditable management-system requirement set. This mapping is a project roadmap, not ISO certification or a completed NIST assessment [2], [3].

Three-tier SETA plan

Awareness, all users: brief secret/privacy and receipt-versus-verification reminders at onboarding and monthly; measure completion and a short quiz. Training, developers/staff: per-release practice of access-control tests, incident triage and restore rehearsal; require execution evidence. Education, project leaders: each milestone discuss risk math, legal duties and framework tradeoffs; use oral scenario defense. These are scheduled proposals; do not invent attendance records.

Git rulebook and exception

Use feature branches and pull requests. Keep `.env`, dumps, raw credentials and production personal data out of Git. Install the hook with `npm run hooks:install`; local hooks can be bypassed, so Gitleaks CI provides a second check. Required CI includes dependency audit, static analysis, security tests, model/risk consistency and ALGOCOM correctness/performance. Normal main policy requires two approvals, stale-review dismissal, a reviewer other than the last pusher, passing `security` and `algocom` checks, linear history and resolved conversations. No force pushes or deletion.

Integration uses the owner's explicitly authorized approval exception: only review requirements are temporarily relaxed after passing checks; restoration is attempted in a finally path and verified. The exact applied state is recorded in the merge ledger. Native GitHub secret scanning/push protection returned unavailable for this private account/repository; do not claim those features were enabled. Privacy remains private unless separately authorized.

V. Asset valuation, TVA and quantitative risk

Four-attribute profile and valuation basis

A-02 is the research-record collection. Business owner: project CEO representing the proposed CRM service; technical custodian: CIO; location: PostgreSQL and temporary recovery copies; classification/criticality: confidential unpublished records with high integrity and availability needs. Existing approved metadata is public. No real university record inventory or incident-loss dataset was supplied.

Retained Lab 5 scenario AV=PHP 3,600,000: engineering/reconstruction 920,000; operational interruption 800,000; response/legal/penalty contingency 1,880,000. These are planning estimates, not invoices, fines, statutory penalty calculations, observed university losses or empirical valuation evidence. The contingency is particularly uncertain. Obtain institutional estimates or documented quotations before budget approval [1], [4].

Five categories and eleven TVA triples

Each row is an explicit threat-agent / vulnerability / asset combination. Five categories have at least two triples; the eleventh adds audit repudiation. Controls are updated to the actual prototype or clearly proposed scope.

TVA / category	Agent	Vulnerability / status	Asset
TVA-01 / Software attacks	External web attacker	The isolated demonstration concatenates SQL; the normal route uses bound parameters. Demonstrated in isolated vulnerable example; mitigated in normal application.	A-02
TVA-02 / Software attacks	Authenticated peer	Omitting per-record authorization would expose another user record; current predicates reject that access. Mitigated scenario; owner/staff checks tested.	A-02
TVA-03 / Human error or failure	Deployment administrator	Temporary pg_dump copies are not encrypted by the application; a local user able to read them can recover records. Current residual risk; no application-level dump encryption.	A-02
TVA-04 / Human error or failure	Developer mistake then external attacker	Accidental committed credentials can be copied from Git history; hooks can be bypassed, so CI is independently required. Mitigated scenario; fake-secret rejection and CI verified.	A-05; A-02
TVA-05 / Espionage or trespass	Authenticated peer exploiting another query flaw	Runtime role can select multiple users rows; application predicates are the isolation boundary and a future missed query could bypass it. Current residual risk; runtime role is not row-isolated.	A-02

TVA / category	Agent	Vulnerability / status	Asset
TVA-06 / Espionage or trespass	Network observer or session thief	Local HTTP carries bearer credentials without TLS; deployment on an untrusted network would expose them. Current transport limitation; local HTTP only.	A-01; A-02
TVA-07 / Information extortion	Ransomware operator	Backup exercise has no independent immutable recovery generation; compromise of the same operator host may destroy both data and reachable copies. Current recovery design gap; extortion is a hypothetical scenario.	A-02
TVA-08 / Information extortion	Ransomware operator with credentials or DB exploit	A stolen administrator credential can alter research data; runtime restriction does not constrain the separately privileged setup identity. Current privileged-account threat scenario; compromise not demonstrated.	A-02
TVA-09 / Sabotage or vandalism	Abusive client	Without bounds, search and graph processing can exhaust resources; current route caps and worker lifecycle limits mitigate that case. Mitigated resource scenario; OS/distributed limits remain.	A-02; A-04; A-08
TVA-10 / Sabotage or vandalism	Compromised or faulty worker process	Status-only worker validation accepted incomplete SUCCESS objects before correction. Demonstrated boundary defect; corrected and regression tested.	A-08
TVA-11 / Sabotage or vandalism	Malicious database administrator	Runtime audit grants prevent modification, but the database owner can still alter or delete audit events. Current residual risk; administrator can alter audit history.	A-07; A-02

These are eleven assessed scenarios across five categories, not eleven currently exploitable defects. The before-fix worker boundary and isolated SQLi have executable reproductions; other rows are mitigated scenarios or explicitly described residual risks. Future uploads, HTML rendering and cloud buckets are excluded from this count. DREAD and financial allocations remain analyst estimates and require team review.

SLE, ALE, safeguard cost and CBA

The scenario follows the course risk arithmetic [4]: SLE=AV×EF; ALE=SLE×ARO; CBA=ALE_before−ALE_after−ACS. Use EF=0.40, prior ARO=2/year, target ARO=0.05/year, annual safeguard cost ACS=PHP 240,000. Thus SLE=1,440,000; prior ALE=2,880,000; target ALE=72,000; CBA=2,568,000; illustrative return on security investment=(2,808,000−240,000)/240,000=1,070%.

This positive result is conditional on the unverified frequency and effectiveness estimates. It is not measured savings or proof that safeguards reduce real incidents to 0.05/year. Do not sum the eleven risk rows' costs again: their allocations partition the same PHP 240,000 bundle. Avoid adding correlated breach losses as if independent.

Sensitivity scenario	AV / EF / ARO before→after	ACS (PHP)	CBA (PHP/year)
Retained planning case	3.6m / .40 / 2→.05	240,000	2,568,000
Lower loss and frequency	1.8m / .20 / .20→.10	240,000	-204,000
Less effective safeguards	3.6m / .40 / 2→1.5	360,000	360,000

Break-even ARO reduction at the base SLE is 240,000/1,440,000=0.1667 events/year. Negative CBA in the low-loss case shows why measured valuation and likelihood inputs matter. Legal/ethical obligations can still require controls even when a narrow monetary calculation is negative.

Nine-column Enterprise Risk Register

Likelihood and impact use ordinal 1–5 project scales; product is a prioritization score, not a probability. Target residual scores are planning assumptions, not validated post-deployment rates. DREAD uses a separate 1–10 scale in Section VI. Risk acceptance remains with the designated project owner after actual review.

Risk ID	Asset	Agent	Root cause	Score	Treatment	Countermeasure	PHP/year	Target
R-01	A-02	External web attacker	The isolated demonstration concatenates SQL; the normal route uses bound parameters.	20	Mitigate	Parameterized search and publication filtering; synthetic exploit comparison and regression tests pass.	44,000	5
R-02	A-02	Authenticated peer	Omitting per-record authorization would expose another user record; current predicates reject that access.	16	Mitigate	Owner-or-staff predicates on records; default denial; cross-user tests pass. Collaborator grants are not implemented.	25,000	4
R-03	A-02	Deployment administrator	Temporary pg_dump copies are not encrypted by the application; a local user able to read them can recover records.	12	Mitigate	Temporary-directory cleanup and controlled operator access; application backup encryption and custody evidence remain proposed.	15,000	4
R-04	A-05; A-02	Developer mistake then external attacker	Accidental committed credentials can be copied from Git history; hooks can be bypassed, so CI is independently required.	20	Mitigate	Pre-commit rejection, Gitleaks CI and protected branches; rotate any real leaked credential. Native private-repo push protection unavailable.	35,000	5
R-05	A-02	Authenticated peer exploiting another query flaw	Runtime role can select multiple users rows; application predicates are the isolation boundary and a future missed query could bypass it.	12	Mitigate	Non-owner runtime and tested application predicates; RLS not implemented.	18,000	4
R-06	A-01; A-02	Network observer or session thief	Local HTTP carries bearer credentials without TLS; deployment on an untrusted network would expose them.	12	Mitigate	Hashed expiring bearer sessions and revocation; local HTTP only. Production HTTPS remains required. No cookie authentication.	8,000	4
R-07	A-02	Ransomware operator	Backup exercise has no independent immutable recovery generation; compromise of the same operator host may destroy both data and reachable copies.	15	Mitigate	Verified local restore is a prerequisite, not offsite resilience. Proposed immutable independent recovery, segregated credentials and rehearsed incident recovery.	16,000	5
R-08	A-02	Ransomware operator with credentials or DB exploit	A stolen administrator credential can alter research data; runtime restriction does not constrain the separately privileged setup identity.	20	Mitigate	Separate non-owner runtime, loopback DB and tested restore; protect setup credentials and add independent immutable backups before production.	48,000	5

Risk ID	Asset	Agent	Root cause	Score	Treatment	Countermeasure	PHP/year	Target
R-09	A-02; A-04; A-08	Abusive client	Without bounds, search and graph processing can exhaust resources; current route caps and worker lifecycle limits mitigate that case.	12	Mitigate	Rate/body limits; staff-only solver; 5000 steps, 25000 edges, 50000 memberships, 2 MiB body; two Python workers, five-second timeout, 8 MiB output ceiling. No OS memory sandbox.	12,000	6
R-10	A-08	Compromised or faulty worker process	Status-only worker validation accepted incomplete SUCCESS objects before correction.	12	Mitigate	Full structural/type/membership validation; malformed object yields WORKER_PROTOCOL/502; worker process is bounded.	12,000	4
R-11	A-07; A-02	Malicious database administrator	Runtime audit grants prevent modification, but the database owner can still alter or delete audit events.	12	Mitigate	Runtime INSERT/SELECT-only audit grants tested; external tamper-resistant audit storage and administrator oversight remain proposed.	7,000	4

Residual scores are targets, not measured post-control frequencies.

VI. Threat Dragon, STRIDE/DREAD and mitigation tickets

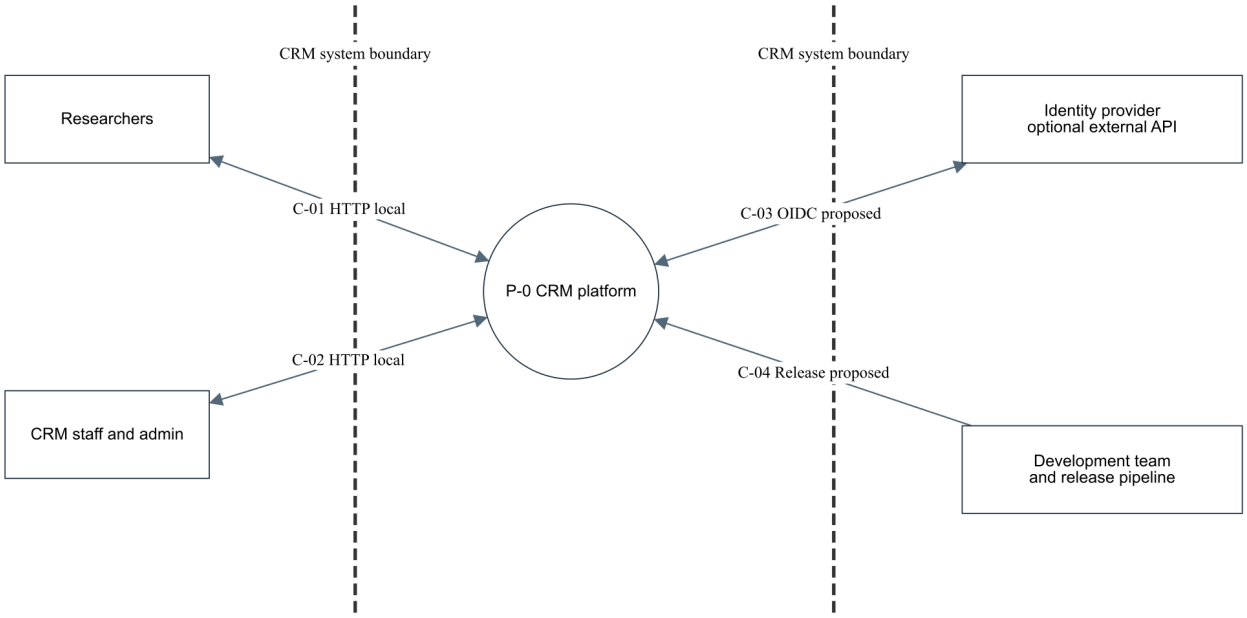
Data flows and trust boundaries

`security/models/CRM_Threat_Dragon.json` is the editable Threat Dragon v2 model, with Level 0 context and Level 1 components. Level 0 has one CRM process. Level 1 separates Express routing, authentication, research/privacy, audit, CI, backup administration and Python worker; logical D-01 operational tables and D-02 audit storage share PostgreSQL but have different grants. D-03 is temporary local backup storage. Identity provider and release/cloud extensions are explicitly proposed [14].

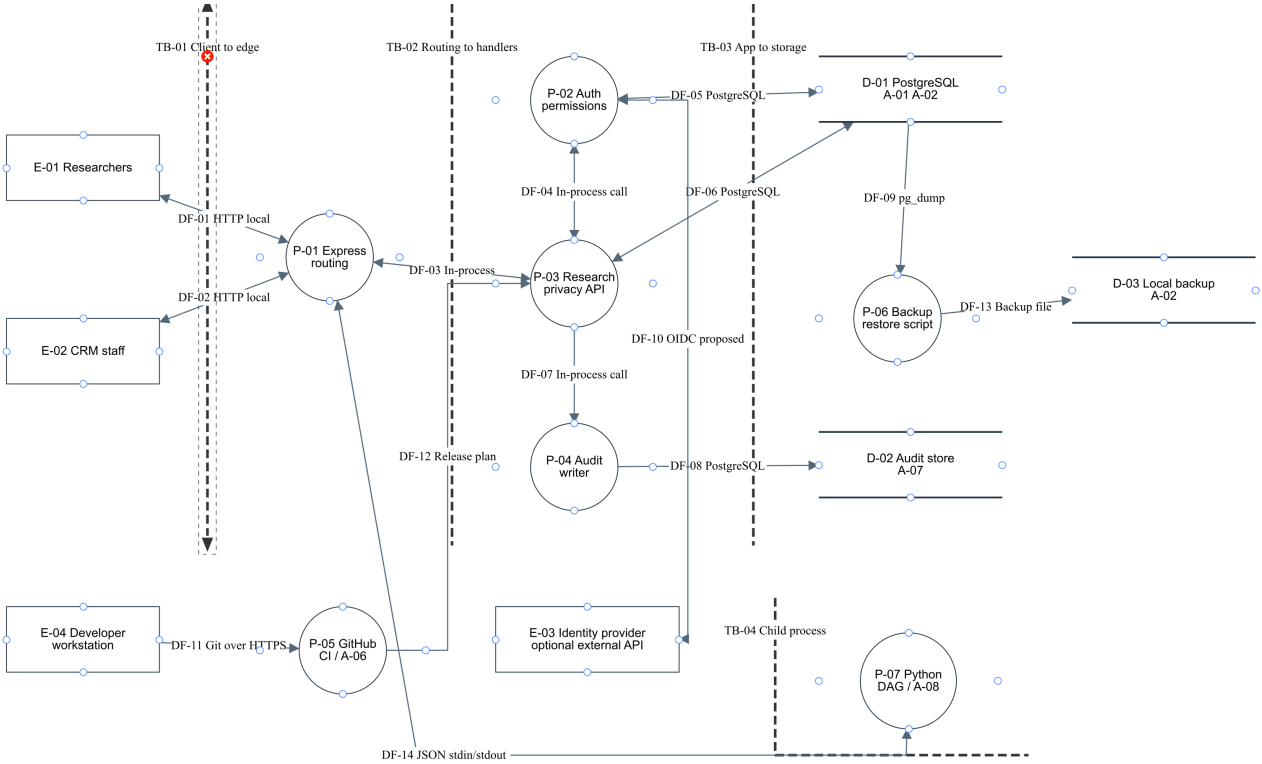
TB-01 crosses client to API; TB-02 is the authorization boundary inside Express, not a separate subnet; TB-03 crosses application to database; TB-04 crosses into the Python child process, not an OS sandbox. DF-14 carries scenario/result JSON over local pipes; it carries no database credentials. P-06 backup reads with a separate administrator identity and writes a temporary dump. Local HTTP and database TCP are not represented as encrypted production transport.

The model passes structural/schema and eleven-threat mapping checks. Current model-derived SVG diagrams accompany this report; both diagrams opened in Threat Dragon 2.6.2. The rendered SVG assets were exported from the browser; raw copies and page-sized copies accompany the model. These are distinct from schema validation and the separately generated report review drawings.

Threat Dragon Level 0



Threat Dragon Level 1



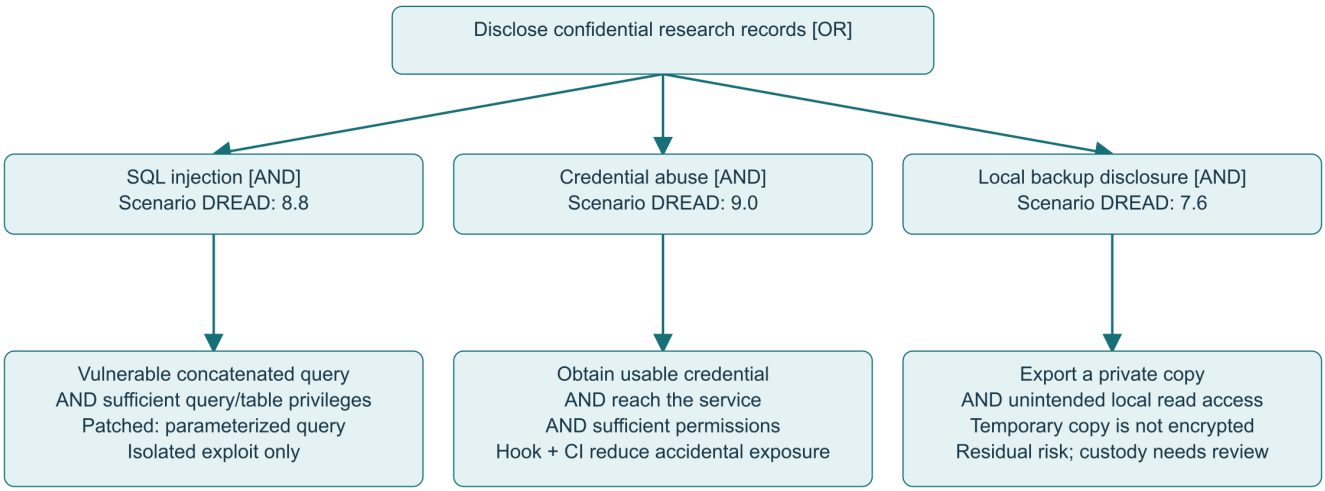
STRIDE and DREAD

STRIDE guides threat discovery across spoofing, tampering, repudiation, information disclosure, denial of service and elevation of privilege [14]. DREAD is a classroom heuristic: Damage, Reproducibility, Exploitability, Affected users, Discoverability are each scored 1–10 and averaged. Ratings are analyst assumptions, not measured attack probabilities or a standardized risk certification. High is at least 7, medium is 4–6.9, low is below 4 for this project.

Threat / element	STRIDE	D,R,E,A,D	Mean	Assessment
THREAT-01 SQL injection / P-03	Tampering; Information disclosure	9,9,8,10,8	8.8	Demonstrated in isolated vulnerable example; mitigated in normal application
THREAT-02 Object authorization bypass / P-03	Information disclosure; Elevation of privilege	8,9,8,7,8	8.0	Mitigated scenario; owner/staff checks tested
THREAT-03 Backup confidentiality exposure / D-03	Information disclosure	8,9,7,7,7	7.6	Current residual risk; no application-level dump encryption
THREAT-04 Committed credentials / E-04	Spoofing; Information disclosure; Elevation of privilege	10,9,8,10,8	9.0	Mitigated scenario; fake-secret rejection and CI verified
THREAT-05 Missing database isolation / D-01	Information disclosure; Elevation of privilege	7,7,5,7,5	6.2	Current residual risk; runtime role is not row-isolated
THREAT-06 Session interception / DF-01	Spoofing; Information disclosure	7,6,5,6,6	6.0	Current transport limitation; local HTTP only
THREAT-07 Loss of recovery copies under extortion / D-03	Tampering; Elevation of privilege	9,7,5,8,6	7.0	Current recovery design gap; extortion is a hypothetical scenario
THREAT-08 Database extortion / D-01	Denial of service; Tampering; Information disclosure	10,8,7,10,8	8.6	Current privileged-account threat scenario; compromise not demonstrated
THREAT-09 Resource exhaustion / P-01	Denial of service	7,9,8,8,6	7.6	Mitigated resource scenario; OS/distributed limits remain
THREAT-10 Malformed worker certificate / P-07	Tampering	7,8,6,6,6	6.6	Demonstrated boundary defect; corrected and regression tested
THREAT-11 Unattributable record changes / D-02	Repudiation; Tampering	7,7,6,6,6	6.4	Current residual risk; administrator can alter audit history

Scores retained as planning assumptions; changed scenario wording requires human reassessment before risk acceptance. Highest priorities remain THREAT-04 (9.0), THREAT-01 (8.8), THREAT-08 (8.6).

AND/OR disclosure attack tree



Scores are planning assumptions, not attack probabilities. AND requires all conditions; OR requires one complete branch.

Root: disclose confidential research records. OR branches: SQL injection; credential abuse; local backup disclosure. SQLi is an AND of a vulnerable concatenated query and sufficient query/table privileges. Credential abuse is an AND of obtaining a usable credential, reaching its service and having sufficient permissions. Local backup disclosure is an AND of an exported private copy and unintended local read access. These are alternative prerequisite paths, not claims that every branch is currently exploitable [15].

Leaf metrics are scenario estimates: query flaw DREAD 8.8; usable credential exposure 9.0; local backup exposure 7.6; reachability/privilege prerequisites assessed jointly, not independently multiplied. “AND” requires all child conditions; “OR” needs any complete branch. The patch removes the demonstrated concatenation condition; secret scanning reduces accidental exposure but cannot prove all credentials safe; no public backup route is implemented; local dump confidentiality still needs operational controls. The editable tree source and image accompany the model.

Top three agile mitigation tickets

Ticket / owner	User story and implementation	Automated assertion / evidence	Remaining acceptance
SEC-04 / Gian	As custodian, prevent accidental credential commits. Install hook, run Gitleaks CI, protect main, document rotation.	`demo:secret` creates fake credential in temp repo and asserts nonzero commit rejection; CI secret scan passes.	Native push protection unavailable; no real compromised credential rotation invented; Aaliyah reviews
SEC-01 / Gian	As researcher, keep private data out of public search. Bind SQL values, filter publication, limit results.	Same UNION payload yields fake sentinel only in isolated vulnerable app; normal response 200/[]; large result set capped at 100.	Broader application penetration review remains
SEC-08 / Justin	As service owner, recover synthetic records without runtime admin privilege. Separate roles, bind DB locally, restore to disposable DB.	pg_dump/pg_restore compares full ordered rows in six tables; runtime audit alteration/drop returns 42501.	Offsite immutable/encrypted backup, deletion replay and production RPO/RTO not validated

Traceability is maintained from asset → TVA → threat → risk → control → ticket → source/test/evidence. `security/data/traceability.csv` and the completion checklist provide exact artifact paths. SEC-09 links A-08/THREAT-09 to worker limits and algorithm tests. Three implementation tickets can be locally tested without pretending the real institution accepted residual risk.

Cross-traceability appendix

Control IDs below identify enforceable rules or explicitly proposed safeguards, not invented ACL implementations.

Asset → TVA → risk → threat	Rule / SysSP control	Ticket → source/test	Status
A-02 → TVA-01 → R-01 → THREAT-01	ACL-01: Public search: bound parameter + Approved + LIMIT 100	SEC-01: scripts/demo-sqli.js; test/security.test.js	Demonstrated in isolated vulnerable example; mitigated in normal application
A-02 → TVA-02 → R-02 → THREAT-02	ACL-02: Record GET: owner or staff; default deny	SEC-02: src/app.js; test/security.test.js	Mitigated scenario; owner/staff checks tested
A-02 → TVA-03 → R-03 → THREAT-03	ACL-03: Backup operator: local only; encryption proposed	SEC-03: scripts/backup-restore.js; docs/PRIVACY.md	Current residual risk; no application-level dump encryption
A-05; A-02 → TVA-04 → R-04 → THREAT-04	ACL-04: Git contributor: hook + required security CI	SEC-04: .githooks/pre-commit; .github/workflows/security-gate.yml	Mitigated scenario; fake-secret rejection and CI verified
A-02 → TVA-05 → R-05 → THREAT-05	ACL-05: Runtime DB: no owner/DDL; RLS proposed	SEC-05: db/schema.sql; test/security.test.js	Current residual risk; runtime role is not row-isolated
A-01; A-02 → TVA-06 → R-06 → THREAT-06	ACL-06: Authenticated API: expiring bearer; TLS proposed	SEC-06: src/crypto.js; src/app.js; docs/CONTROLS.md	Current transport limitation; local HTTP only
A-02 → TVA-07 → R-07 → THREAT-07	ACL-07: Recovery operator: independent immutable copy proposed	SEC-07: scripts/backup-restore.js; proposed offsite design only	Current recovery design gap; extortion is a hypothetical scenario
A-02 → TVA-08 → R-08 → THREAT-08	ACL-08: Runtime DB deny DDL; admin privilege separate	SEC-08: compose.yaml; db/schema.sql; scripts/backup-restore.js	Current privileged-account threat scenario; compromise not demonstrated
A-02; A-04; A-08 → TVA-09 → R-09 → THREAT-09	ACL-09: Staff solve: 2 MiB/2 jobs/5 sec; graph caps	SEC-09: src/algorithm.js; algocom/engine.py; test/algorithm.test.js	Mitigated resource scenario; OS/distributed limits remain
A-08 → TVA-10 → R-10 → THREAT-10	ACL-10: Worker output: complete certificate validation	SEC-10: src/algorithm-result.js; test/algorithm-result.test.js; test/algorithm.test.js	Demonstrated boundary defect; corrected and regression tested
A-07; A-02 → TVA-11 → R-11 → THREAT-11	ACL-11: Audit runtime: INSERT/SELECT; deny UPDATE/DELETE	SEC-11: db/schema.sql; test/security.test.js	Current residual risk; administrator can alter audit history

Financial evidence worksheet — external action required

No actual cost records or instructor approval of estimates have been supplied. Aaliyah owns completion; the proposed figures above must not be described as empirical institutional valuation.

Input	Required source	Actual value / evidence	Reviewer / date
Replacement effort	Logged work hours and supported labor rate	Not supplied	Unsigned
Service interruption	Documented affected volume and measured downtime	Not supplied	Unsigned
Response and privacy cost	Quote, invoice or approved cost basis	Not supplied	Unsigned
Safeguard annual cost	Tool quote and staff-maintenance estimate basis	Not supplied	Unsigned
Exposure and event frequency	Incident data or explicitly approved scenario assumptions	Not supplied	Unsigned

Input	Required source	Actual value / evidence	Reviewer / date
Estimate exception	Instructor decision with date and permitted scope	Not supplied	Unsigned

Use `docs/FINANCIAL_EVIDENCE_WORKSHEET.md` to record sources and the draft clarification. An instructor decision cannot be assumed and would not turn estimates into observed costs.

Demonstration, verification and remaining decisions

The 60-second real terminal capture is `evidence/integration/secret-demo.cast`, with a standalone replay in `secret-demo.html`. It uses a deliberately fake secret in a temporary repository; nothing secret is pushed. Speaking script: 0–8s introduce A-05 and THREAT-04; 8–35s run and explain rejection; 35–50s connect the hook and Gitleaks to SEC-04; 50–60s state the limit: hooks can be bypassed and human review/credential rotation remain separate. The replay is an actual timed terminal capture, not a recording of a team member speaking.

Executed checks include authentication/ownership/privacy and DB grants, solver errors and equivalent results, SQLi before/after, secret rejection, synthetic restoration, static checks, dependency audit and model arithmetic/schema validation. GitHub runs Gitleaks and Semgrep in addition to local invariants. Refer to commit-bound logs; do not label a check passed merely because its script exists.

Remaining external decisions: actual staff/institutional confirmation of procedures, retention and financial estimates; teammate understanding and review; institutional production authorization; instructor acceptance; designated TBL Hub submission. No invented dates, appointments or signatures fill these gaps.

AI collaboration and tool disclosure

ChatGPT/Codex assisted source reconciliation, substantial backend/worker and test drafting, threat/risk refinement, financial checks, diagram/report assembly and CI/evidence packaging. Claude assistance disclosed in the supplied sections is retained. Verification used executed tests, equivalent-baseline comparisons, arithmetic/schema checks, source checks and rendered-page inspection. Automated verification is distinct from human review; the team must validate assumptions and defend the final work.

References

[1] bolanatics, CRM Labs 1–6 and IAS PBL Team Task Guide, supplied completed course drafts, 2026; University of Makati, Research Manual, supplied PDF, revised 2025. Institutional applicability requires confirmation.

[2] NIST, The NIST Cybersecurity Framework (CSF) 2.0, CSWP 29, Feb. 2024. https://doi.org/10.6028/NIST.CSWP.29

[3] ISO/IEC, ISO/IEC 27001:2022 — Information security management systems — Requirements, 2022. https://www.iso.org/standard/27001

[4] M. E. Whitman and H. J. Mattord, Principles of Information Security, 7th ed. Cengage, copyright 2022 (published 2021). https://www.cengage.com/c/principles-of-information-security-7e-whitman-mattord/9780357506431/

[5] OWASP, Application Security Verification Standard, v5.0.0, May 2025. https://github.com/OWASP/ASVS/tree/v5.0.0

[6] MITRE, Common Weakness Enumeration: CWE-89, CWE-862 and CWE-400, current technical entries, accessed Oct. 4, 2026. https://cwe.mitre.org/data/definitions/89.html ; https://cwe.mitre.org/data/definitions/862.html ; https://cwe.mitre.org/data/definitions/400.html

[7] Lockheed Martin, Cyber Kill Chain, foundational model introduced 2011; official current overview, accessed Oct. 4, 2026. https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html

[8] MITRE, ATT&CK Enterprise techniques T1595.002, T1587.001, T1566.001, T1204.002, T1053.003, T1071.001 and T1486, current entries, accessed Oct. 4, 2026. https://attack.mitre.org/

[9] Republic of the Philippines, Republic Act No. 10173, Data Privacy Act of 2012, 2012. Official NPC text: https://privacy.gov.ph/data-privacy-act-/

[10] Republic of the Philippines, Republic Act No. 10175, Cybercrime Prevention Act of 2012, 2012. Senate legislative record: https://issuances-library.senate.gov.ph/legislative%2Bissuances/Republic%20Act%20No.%2010175

[11] National Privacy Commission, Circular 16-03, Personal Data Breach Management, 2016; official breach-reporting guidance accessed Oct. 4, 2026. https://privacy.gov.ph/wp-content/uploads/2016/12/sgd-npc-circular-16-03-personal-data-breach-management.pdf ; https://privacy.gov.ph/pips-and-pics/breach-reporting/

[12] NIST, Incident Response Recommendations and Considerations for Cybersecurity Risk Management, SP 800-61 Rev. 3, 2025. https://csrc.nist.gov/pubs/sp/800/61/r3/final

[13] PostgreSQL Global Development Group, PostgreSQL 18 Documentation: Privileges, 2025 release documentation, accessed Oct. 4, 2026. https://www.postgresql.org/docs/18/ddl-priv.html

[14] OWASP, Threat Dragon v2.6.2 documentation and Developer Guide threat modeling guidance, accessed Oct. 4, 2026. https://www.threatdragon.com/docs/ ; https://devguide.owasp.org/en/04-design/01-threat-modeling/03-threat-dragon/

[15] B. Schneier, “Attack Trees,” Dr. Dobb's Journal, Dec. 1999. https://www.schneier.com/academic/archives/1999/12/attack_trees.html

[16] NIST, Guidelines for Media Sanitization, SP 800-88 Rev. 2, Sep. 2025. https://csrc.nist.gov/pubs/sp/800/88/r2/final

[17] National Privacy Commission, Advisory 2021-01, Data Subject Rights, sec. 10, 2021. https://privacy.gov.ph/wp-content/uploads/2021/02/NPC-Advisory-2021-01-FINAL.pdf

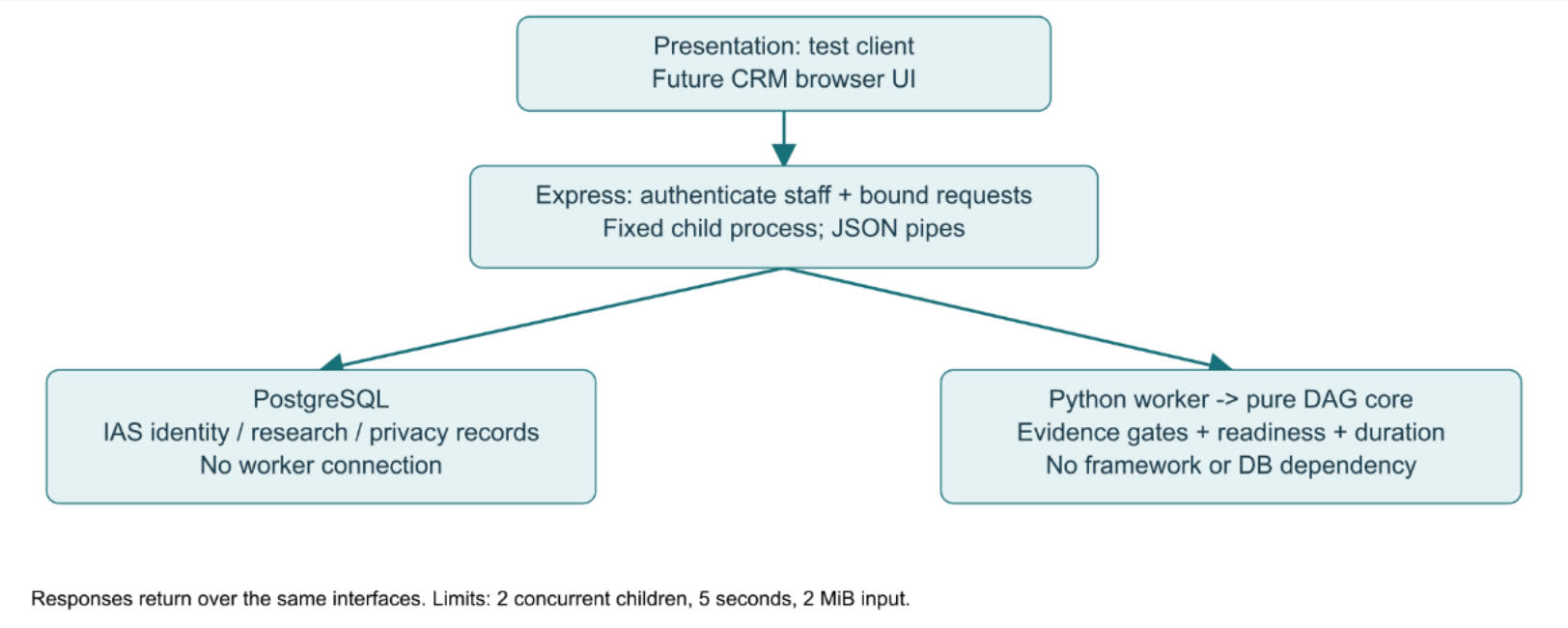
Recent standards are favored. Required older statutes, NPC circular and foundational works retain their real dates; an access date is not a publication date. The 14-slide executive deck follows these references. Empirical valuation, genuine signatures and institutional acceptance remain external requirements.

CRM application security architecture

Anjelo Benedict Arnaez · K12254175	CEO / executive sponsor
Justin Andrew Ducay · A12448793	CIO / infrastructure lead
Aaliyah Marie Balocating · A12448769	CISO / risk lead
Gian Brent Maligaya · A12448912	Lead Engineer / DevSecOps
John David Bomediano · A12448927	DPO / compliance specialist

III-BCSAD · bolanatics · 5 October 2026

System architecture and real prototype assets



A-01 identity · A-02 research · A-05 credentials

A-06 source · A-07 audit · A-08 solver scenarios

A-03 persistent workflow is proposed; all records are synthetic.

[1]–[4]; asset classifications in report I

Attack surfaces and seven-stage scenario

Phase	Workstation-to-database hypothesis	MITRE ID
Recon	Discover reachable service	T1595.002
Weaponize	Prepare credential-stealing file	T1587.001
Deliver	Phish developer with attachment	T1566.001
Exploit	User executes malicious file	T1204.002
Install	Persist in user cron	T1053.003
C2	Contact attacker web endpoint	T1071.001
Objective	Encrypt accessible A-02 records	T1486

[7], [8]. Hypothetical only. Surfaces: HTTP API, worker pipes, local DB, developer credentials.

SQL injection: same payload, verified outcomes

VULNERABLE (isolated demo)
SQL contains keyword directly:
... title ILIKE '%${keyword}%'

Payload: ' UNION SELECT id, email,
password_hash, role FROM users--

HTTP 200: synthetic@example.test
and FAKE_HASH_NOT_A_CREDENTIAL

PATCHED (normal application)
WHERE status='Approved'
AND title ILIKE $1
ORDER BY id LIMIT 100

Values: ['%'+keyword+'%']

Same payload: HTTP 200, []
Bound value remains data, not SQL.

[5], [6]. Actual synthetic responses: evidence/integration/local-checks.txt; demo:sqli.

Privacy and Philippine law mappings

RA 10173: transparency, purpose, proportionality, rights, security.
RA 10175: illegal access; interception; data or system interference; misuse of devices.

Five provisions from each law map to controls and owners in III.

```
POST /api/v1/users/consent
{ "policy_version":"2026-10-v1",
  "choices":{
    "institutional_analytics":false,
    "email_notifications":false }}
```

Identity and time: server-derived.
Hard deletion works on live rows; backup/key erasure remains proposed.

[9]–[11], [16], [17]; classroom mapping, not institutional legal approval.

Incident response and NPC notification

01 Identify → Contain → Analyze → Eradicate → Recover → Lessons learned.

02 Draft notice: affected data, scope, discovery time, containment, contact and next update; fill only verified facts.

03 Academic simulation. DPO assesses whether notification conditions trigger the 72-hour requirement. No notice was sent.

[11], [12]; NPC notification draft in report III.

EISP and default-deny access rules

Subject	Object	Action	Constraint	Decision
Anonymous	Search	POST	Approved; ≤100 rows	Allow
Student	Record	GET	Owner only	Allow
Staff	Algorithm	POST	Auth + bounded job	Allow
Runtime	Audit	UPDATE/DELETE	Any context	Deny
*	All routes	Any	Unmatched permission	Deny

EISP: philosophy · scope · roles · statutory directives · review cadence.

NIST: prioritize now; ISO: staged governance. SETA: awareness, practice, education.

[2], [3], [13]; complete ACL and implementation evidence in report IV.

Git controls and the 60-second demonstration

01 Normal main: 2 approvals, strict security + algocom checks; stale/last-push review rules; no force pushes.

02 Replay secret-demo.html: A-05 → THREAT-04 → ACL-04 → SEC-04. A fake secret commit is actually rejected.

03 Hooks are bypassable; Gitleaks CI is independent. Prior authorized merge exception was restored and is not peer review.

PR #3 / bbe0a73; correction PR records its own final checks. Native private-repo secret scanning unavailable.

Financial valuation: estimates, not actual loss

Calculation	PHP / assumption
Asset value	3,600,000 (unsupported estimate)
SLE = AV × .40	1,440,000
ALE prior / post	2,880,000 / 72,000
Annual safeguard cost	240,000
CBA = prior − post − cost	2,568,000
Lower-loss sensitivity CBA	−204,000

[4]. Empirical valuation remains incomplete; Aaliyah must obtain evidence or instructor guidance.

Enterprise risk register: highest priorities

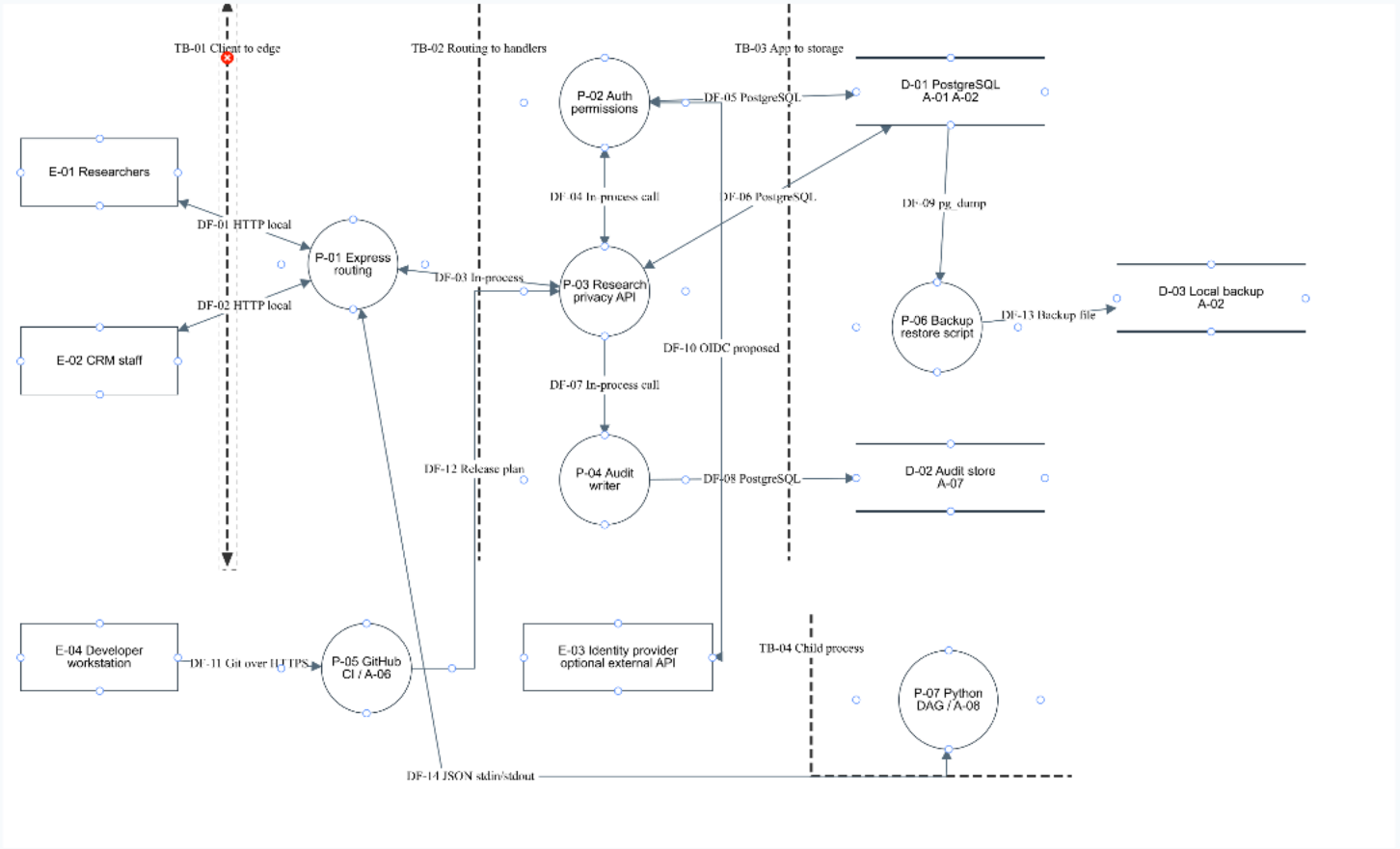
ID	Asset	Agent	Weakness	Score	Treatment	Control	PHP/yr	Target
R-04	A-05	Developer / attacker	Secret commit	20	Mitigate	Hook + CI	35,000	5
R-01	A-02	Web attacker	Unsafe SQL	20	Mitigate	Bound SQL	44,000	5
R-08	A-02	Privileged attacker	Admin compromise	20	Mitigate	Grants; restore	48,000	5

Full nine-column register contains all eleven scenarios in report V.

Targets and DREAD scores are estimates; acceptance requires actual review.

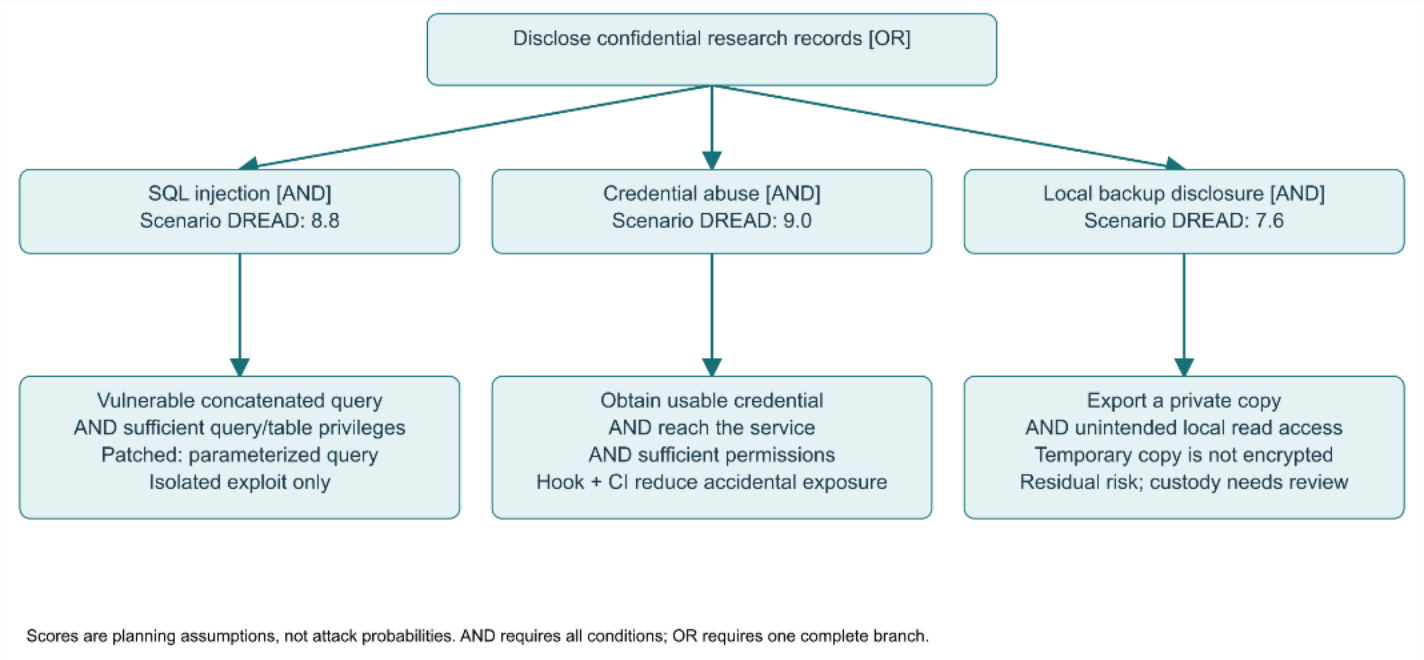
[4]; security/data/risks.json is the calculation source.

Threat Dragon Level 1 and trust boundaries



[14]. TB-01 client; TB-02 authorization; TB-03 DB grants; TB-04 child process (not OS sandbox).

STRIDE and the AND/OR disclosure tree



Actor spoofing · process tampering · flow interception · store disclosure/repudiation.

DREAD leaders: credentials 9.0; SQLi 8.8; privileged extortion 8.6.

[14], [15]; AND needs every child, OR needs any complete branch. Metrics are analyst estimates.

Security tickets and executable acceptance

Ticket / owner	Control linked to asset	Assertion
SEC-04 / Gian	A-05: reject secret commits	Nonzero commit rejection; CI scan
SEC-01 / Gian	A-02: parameterize search	UNION disclosure only in demo
SEC-08 / Justin	A-02: recover synthetic DB	Six tables restored; runtime denies DDL
SEC-10 / Gian	A-08: validate worker result	Malformed SUCCESS → 502

CISO reviews traceability; each member independently verifies their own work.

Report VI and cross-traceability appendix; tests do not prove human acceptance.

References and remaining external actions

[1] bolanatics / UMak, CRM Labs 1–6 and Research Manual, 2025–2026.

[2] NIST, Cybersecurity Framework 2.0, CSWP 29, 2024.

[3] ISO/IEC, ISO/IEC 27001:2022, 2022.

[4] Whitman and Mattord, Principles of Information Security, 7th ed., 2022.

[5] OWASP, Application Security Verification Standard 5.0, 2025.

[6] MITRE, CWE-89, CWE-862, CWE-400, accessed 2026.

[7] Lockheed Martin, Cyber Kill Chain, 2011; accessed 2026.

[8] MITRE, ATT&CK Enterprise technique entries, accessed 2026.

[9] Philippines, RA 10173: Data Privacy Act, 2012.

[10] Philippines, RA 10175: Cybercrime Prevention Act, 2012.

[11] NPC, Circular 16-03: Personal Data Breach Management, 2016.

[12] NIST, Incident Response Recommendations, SP 800-61 Rev. 3, 2025.

[13] PostgreSQL, PostgreSQL 18: Privileges, 2025.

[14] OWASP, Threat Dragon and threat modeling guidance, accessed 2026.

[15] B. Schneier, “Attack Trees,” Dr. Dobb’s Journal, 1999.

[16] NIST, Media Sanitization, SP 800-88 Rev. 2, 2025.

[17] NPC, Advisory 2021-01: Data Subject Rights, 2021.

Full IEEE references and links appear before this deck. Team review, signatures, real valuation and TBL submission remain.